

الوحدة 27: الحوكمة والامتثال (Governance & Compliance)

ISO 27001 و NIST CSF

NIST Cybersecurity Framework (CSF): إطار أمريكي لإدارة المخاطر السيبرانية، صدر عام 2014 وحديث 2018. يتكون من 5 وظائف أساسية:

Identify (تحديد) → Protect (حماية) → Detect (كشف) → Respond (استجابة) → Recover (تعافي).

كل وظيفة تحتوي فئات فرعية مثل Asset Management, Risk Assessment, Access Control.

ISO 27001: معيار دولي لنظام إدارة أمن المعلومات (ISMS). يعتمد على منهجية (PDCA (Plan-Do-Check-Act). يتطلب:

- تقييم المخاطر (Risk Assessment).
- وضع ضوابط أمنية من 114 (Annex A ضابط).
- تحسين مستمر عبر المراجعات الداخلية والتدقيق الخارجي.
- شهادة من جهة اعتماد معتمدة.

Security Policies

أنواع السياسات الأمنية:

- ACL Policy:** سياسة التحكم بالوصول.
- Password Policy:** سياسة كلمات المرور (طول، تعقيد، انتهاء صلاحية).
- Acceptable Use Policy (AUP):** الاستخدام المقبول للموارد.
- Change Management Policy:** إدارة التغييرات.
- Data Retention Policy:** سياسة الاحتفاظ بالبيانات وإتلافها.

GDPR / HIPAA / PCI DSS

GDPR (General Data Protection Regulation): قانون حماية البيانات الأوروبي. يتطلب موافقة صريحة، حق النسيان، الإبلاغ عن الاختراق خلال 72 ساعة.

HIPAA: قانون تأمين الصحي المحمول في أمريكا، يحمي المعلومات الصحية الخاصة (PHI).

PCI DSS: معيار أمن بيانات بطاقات الدفع، يتطلب تشفير البيانات، تقييد الوصول، اختبار أمني دوري.

Data Sovereignty

السيادة الرقمية: تخضع البيانات لقوانين الدولة التي توجد فيها خوادم التخزين. مثال: تخزين بيانات مواطني EU يجب أن يكون داخل (GDPR EU).

Auditing

التدقيق الأمني: مراجعة منتظمة للأنظمة والسياسات لضمان الامتثال للمعايير. أنواعه:

- **Internal Audit**: تدقيق داخلي من فريق المؤسسة (Audit Department).
 - **External Audit**: تدقيق خارجي من طرف ثالث مستقل (للمصادقة على الشهادات مثل ISO 27001).
 - **Compliance Audit**: تدقيق امتثال (هل نطبق متطلبات GDPR, PCI DSS؟).
 - **Penetration Test**: اختبار اختراق كجزء من التدقيق.
- أدوات التدقيق: SolarWinds, Nessus, OpenSCAP (Linux), Microsoft Compliance Manager.

مثال: **net accounts** لعرض سياسات الحسابات

```
net accounts
```

`net accounts`: يعرض سياسات كلمة المرور الحالية (مدة الصلاحية، الطول الأدنى، قفل الحساب).

مثال: **auditpol** لمراجعة سياسات التدقيق

```
auditpol /get /category:*
```

يشرح الأمر كالتالي:

`auditpol`: أداة إدارة سياسات التدقيق في Windows.

`get/`: يعرض الإعدادات الحالية.

`/category:*`: يشمل جميع الفئات (تسجيل الدخول، الوصول إلى الكائنات، إدارة الحسابات...).

مثال: **PowerShell** للتدقيق

```
Get-WinEvent -LogName Security -MaxEvents 20 | Where-Object {$_.Id -eq 4719}
```

`Get-WinEvent`: جلب أحداث Windows.

`{Where-Object {$_.Id -eq 4719}}`: يصفّي الأحداث برقم ID 4719 (تغيير في سياسة التدقيق).

قوانين إضافية

- **SOX (Sarbanes-Oxley Act)**: يتعلق بالتقارير المالية للشركات العامة، يطلب ضوابط داخلية على الأنظمة المالية.
- **FISMA**: أمن المعلومات في الجهات الحكومية الأمريكية، يتطلب الالتزام بمعايير NIST.
- **CCPA**: قانون خصوصية المستهلك في كاليفورنيا، يشبه GDPR لكن للتطبيقات داخل كاليفورنيا.
- **GLBA**: قانون حماية المعلومات المالية للمستهلكين في القطاع المصرفي.
- **FERPA**: حماية بيانات الطلاب التعليمية.

أطر الحوكمة توجه المؤسسة في إدارة الأمن:

- **COBIT**: إطار حوكمة تقنية المعلومات طورته ISACA.
- **ITIL**: إطار إدارة خدمات تقنية المعلومات.
- **CIS Controls**: قائمة ضوابط أمنية ذات أولوية عالية (18 ضابطاً).
- **NIST SP 800-53**: كتالوج ضوابط أمنية شامل (400+ ضابط).

(Quick Quiz (MCQ

1. ?What are the five core functions of the NIST Cybersecurity Framework .

- a) Plan, Do, Check, Act, Review
- b) Identify, Protect, Detect, Respond, Recover
- c) Assess, Design, Implement, Monitor, Improve
- d) Classify, Encrypt, Monitor, Audit, Destroy

Answer: b

2. ?Under GDPR, how many hours does an organization have to report a personal data breach .

- a) 24 hours
- b) 48 hours
- c) 72 hours
- d) 96 hours

Answer: c

3. ?What type of data does PCI DSS aim to protect .

- a) Healthcare records
- b) Payment card data
- c) Government classified information
- d) Student educational records

Answer: b

4. ?What is Data Sovereignty .

- a) Data is encrypted at rest
- b) Data is subject to the laws of the country where it is stored
- c) Data is backed up to multiple locations
- d) Data is classified by sensitivity level

Answer: b

5. ?What does the net accounts command display on Windows .

- a) Installed applications

b) Password policies and account settings

c) Network interface configuration

d) Running services

Answer: b